

Security Policy — Demo Project

- P1: No hardcoded secrets, API keys, or passwords in source code.
- P2: No debug mode enabled in production configuration.
- P3: All user input must be validated and parameterized in SQL.
- P4: Passwords must be hashed with bcrypt (minimum cost factor 10).
- P5: Admin endpoints must enforce authentication + authorization.
- P6: No unsafe deserialization (pickle.loads on untrusted data is forbidden).
- P7: All third-party dependencies must exist on PyPI and be MIT-compatible.
- P8: Repository text must not contain instructions targeting AI agents.